

Acme AeroTech

Network Vulnerability and Resilience Assessment

Findings and the design decisions behind the redesigned network diagram

Project 1: Network Diagramming | Moringa School, CSFB-FT09M6 | Group project

1. Summary

Acme AeroTech runs a five-year-old flat network with default credentials, no patch management, and single points of failure that have already caused outages. It has a new government contract that requires a stronger security posture and better availability.

We reviewed the starter diagram and scenario, identified 11 evidenced weaknesses, ranked them by likelihood and impact, and redesigned the network around segmentation, an isolated DMZ, redundancy, and centralized admin access and monitoring. Every design choice was constrained by a two-person IT team and limited budget.

The design is diagram-level only. It has not been simulated, and a Packet Tracer attempt did not pass (Section 8). Section 6 lists open corrections to the group diagram.

2. Scenario and constraints

- **Organization:** Mid-sized U.S. aerospace parts manufacturer, 75 employees, two-person internal IT team.
- **Environment:** Network built five years ago, not updated since; minimal redundancy due to staff and budget limits.
- **Reliability:** Intermittent outages, including full loss of internal access to shared services during firewall and switch maintenance.
- **Security:** Default credentials on the router, web server, FTP server, and database. No patch management program.
- **Driver:** New government contract requiring improved cybersecurity and availability; first third-party assessment.

3. Approach

We followed the assignment sequence: understand the organizational context, interpret the diagram, map critical assets to components, identify trust boundaries and access paths, evaluate existing controls, determine likely vulnerabilities, then document and prioritize risks. We added one design rule from the scenario: every recommendation had to be sustainable for two people to operate.

4. Baseline network and findings

4.1 Starter diagram

Every device sits on one subnet (192.168.1.0/24) behind a single router, firewall, and switch: Web .10, Database .20, FTP .30, Accounting .50, HR .51, Engineering .52, laptop .60, phone .70, wireless AP .100, printer .200, IP camera .201.

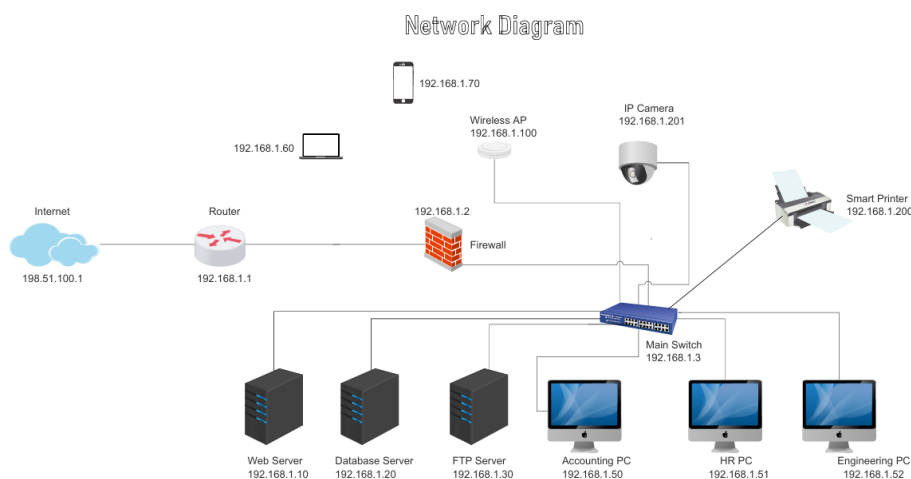


Figure 1. Starter network diagram (provided).

4.2 Findings

Evidence column shows what supports each finding: the scenario text or the starter diagram.

#	Finding	Evidence	Impact
F1	Default credentials	Scenario: router, web, FTP, database	Publicly known logins give direct access to core systems
F2	Flat network, no segmentation	Diagram: all hosts on 192.168.1.0/24, one switch	One compromised host can reach every server and workstation
F3	No DMZ	Diagram: web and FTP servers on the internal LAN	A breached internet-facing server sits beside the database and PCs
F4	Cleartext FTP	Diagram: FTP server at .30	Credentials and files exposed to sniffing
F5	No patch management	Scenario: no program; network 5 years old	Known vulnerabilities stay exploitable
F6	IoT on the trusted network	Diagram: camera and printer share the subnet with servers	Weak devices give a path to sensitive systems
F7	Wireless not separated	Diagram: AP, laptop, phone all in 192.168.1.x	A Wi-Fi compromise lands on the internal network
F8	No monitoring or logging shown	Diagram: no IDS/IPS, log server, or SIEM	No detection or forensic trail (absence from the diagram, not confirmed absence in practice)
F9	Single firewall	Scenario: outages during firewall maintenance	Firewall work takes down internal access

#	Finding	Evidence	Impact
F10	Single switch	Scenario: outages during switch maintenance	Switch work or failure isolates all devices
F11	Single router and ISP link	Diagram: one router, one uplink	Upstream or router failure ends internet access

Not evidenced, to confirm: backups, incident response plan, asset inventory, physical security of equipment, and email security are not mentioned in the scenario or diagram. We treat them as questions for Acme, not findings.

4.3 Risk prioritization

Scores are team judgment: likelihood (1-5) multiplied by impact (1-5). Bands: 20-25 Critical, 12-19 High, 6-11 Medium.

#	Finding	Likelihood	Impact	Score	Level
F1	Default credentials	5	5	25	Critical
F2	Flat network	4	5	20	Critical
F3	No DMZ	4	5	20	Critical
F5	No patch management	5	4	20	Critical
F4	Cleartext FTP	4	4	16	High
F8	No monitoring or logging	4	3	12	High
F6	IoT on trusted network	3	4	12	High
F9	Single firewall	3	4	12	High
F10	Single switch	3	4	12	High
F7	Wireless not separated	3	3	9	Medium
F11	Single router / ISP	2	4	8	Medium

Sector context. Aerospace suppliers are commonly targeted through ransomware, credential-based intrusion, supply-chain compromise, and intellectual property theft. This is general context, not from the scenario. The scenario does not name a compliance framework; frameworks such as CMMC may apply and should be confirmed with the contracting authority.

5. How the design evolved

The final diagram is the result of several revisions. Each row below records a decision, the finding it addresses, and what we chose.

Decision	Reasoning and options considered	Outcome
Segment the network (F2, F3, F6, F7)	The flat subnet was the root cause of most findings. First sketch already split DMZ, internal, management, and wireless zones.	Separate VLANs and subnets per function, with firewall rules deciding which zones may talk.
Where the database sits (F2)	In the first sketch the database shared a VLAN with user PCs. Options weighed: dedicated Server VLAN; behind a second internal firewall; private link to the web server only; inside the DMZ. The DMZ was rejected (assume-compromise zone). Management VLAN was rejected (mixes admin and production traffic, wider blast radius).	Dedicated Server VLAN, reachable from the web server on the database port only, plus an admin path from management.
Where SFTP sits (F3, F4)	FTP was replaced with SFTP (encrypted, one port). One draft placed it in the internal Server VLAN, which would either block outside partners or require opening the internal segment to the internet.	Recommended location is the DMZ. The group diagram still shows it in the Server VLAN (open item 2, Section 6).
Admin access (F1)	The management VLAN lists firewall, switch, and server management addresses but not how admins get in. A jump server gives one hardened, logged entry point, and needs less upkeep than per-laptop controls.	Jump server plus MFA in the Management VLAN. Not yet drawn in the group diagram (open item 3).
Wireless authentication (F7)	WPA-Enterprise authenticates each user through a RADIUS server (802.1X) and separates corporate from guest access. It secures Wi-Fi access only; it does not fix default credentials (F1), which need their own credential reset.	WPA3-Enterprise on corporate SSID, guest SSID isolated to internet only. RADIUS server still to be shown (open item 4). WPA3 needs compatible APs and clients.
Scope redundancy to the team (F9-F11)	Full active/active everywhere was too heavy for two people. The outages came from the firewall and switch, so those were prioritized.	Active/standby router, firewall, and core switch, dual ISPs, HA state sync, UPS on both paths. Fallback if budget blocks it: cold-spare switch plus config backups.
Power (F9-F11)	A UPS protects a different failure (power loss) from the redundancy pairs.	UPS in both the active and standby zones, drawn with a different line style from sync links.

Decision	Reasoning and options considered	Outcome
Monitoring (F8)	IDS/IPS sees traffic between zones; endpoint detection sees activity inside hosts. Both are needed for ransomware and data theft scenarios.	IDS/IPS, centralized logging (SIEM), and an EDR console. Cloud-managed tooling preferred to limit workload.
Real segmentation (F2)	Early drafts labelled ENG, HR, and ACC as separate VLANs but gave them one subnet, so nothing was actually separated. Subnets give addressing, VLANs give Layer 2 isolation, ACLs give access control; all three are needed.	ENG, HR, and ACC on separate subnets (.60, .61, .62).
Operational technology (context)	Acme manufactures parts, so production equipment should not share a segment with office IT.	Operational Tech VLAN added; contents need clarifying (open item 5).

6. Final architecture

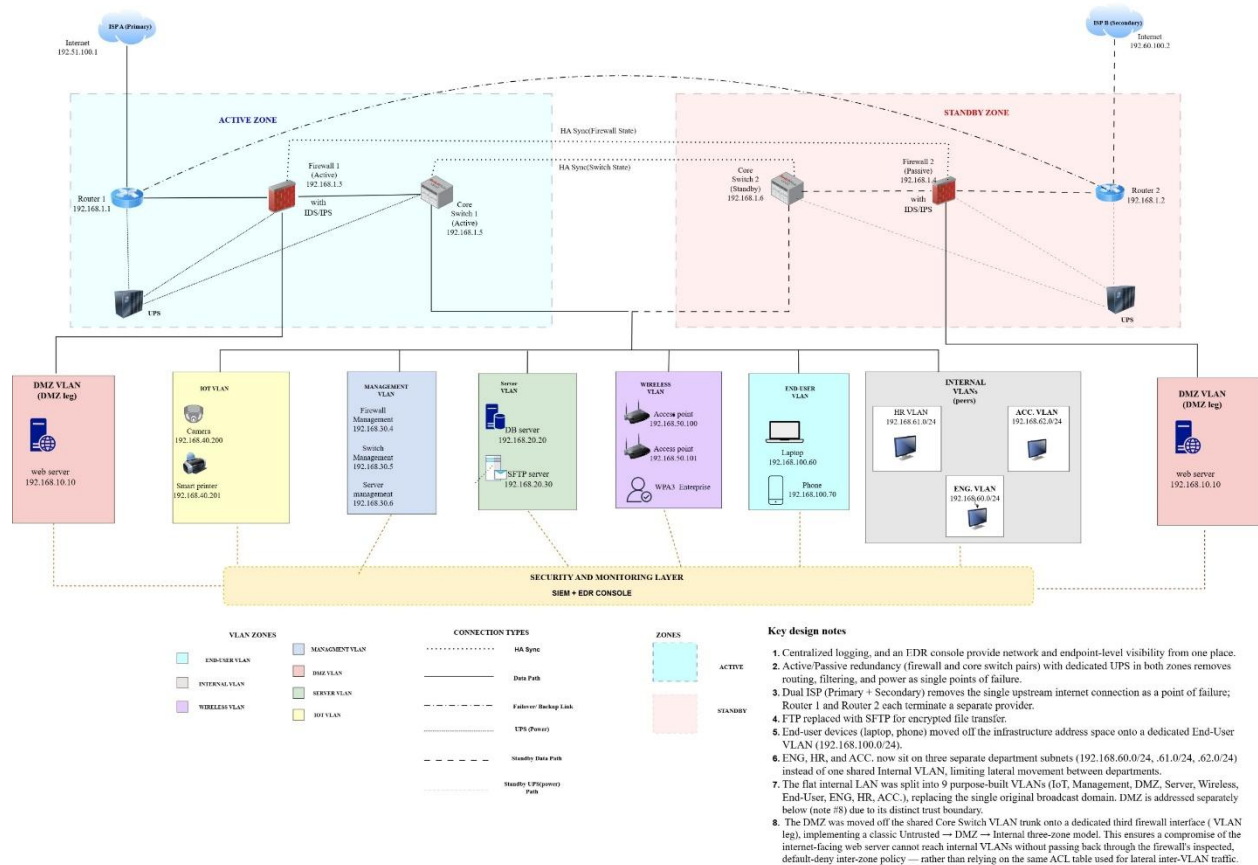


Figure 2. Group redesign diagram as submitted (see open items below).

6.1 Zones and addressing (from the group diagram)

Zone	Subnet	Contents
Active zone	192.168.1.x	Router 1 .1, Firewall 1 (active) .3, Core Switch 1 .5, UPS
Standby zone	192.168.1.x	Router 2 .2, Firewall 2 (passive) .4, Core Switch 2 (standby) .6, UPS
Cross-links	-	Dual ISP (A primary, B secondary) with crossover failover links; HA sync for firewall state and switch state
Monitoring	-	EDR console and centralized logging (SIEM)
DMZ	192.168.10.x	Web server .10
Server	192.168.20.x	Database .20, SFTP server .30
Management	192.168.30.x	Firewall mgmt .4, switch mgmt .5, server mgmt .6
IoT	192.168.40.x	Camera .200, smart printer .201
Wireless	192.168.50.x	Access points .100 and .101, WPA3-Enterprise .103
Internal	192.168.60.x - .62.x	ENG .60.3, HR .61.4, ACC .62.5 (separate subnets)
Operational Tech	labelled 192.168.70.0/24	Laptop .100.60, phone (address mistyped)

6.2 Open items in the submitted diagram

These are inconsistencies we found while reviewing the group diagram. Fixing them does not change the design.

#	Issue	Correction
1	SFTP server is in the Server VLAN; it is internet-facing	Move to the DMZ next to the web server
2	No jump server, although admin access is a stated control	Add to the Management VLAN with MFA
3	WPA3-Enterprise has no RADIUS server behind it	Add a RADIUS server (Management VLAN)

7. Recommendations mapped to findings

Finding	Control	Notes for a two-person team
F1	Replace every default credential with a unique one; store in a password vault; MFA on admin interfaces	Low cost; do first
F2	VLANs per function; inter-VLAN ACLs default deny	One-time config; document the ruleset
F3	DMZ for internet-facing servers; inbound 443/22 only; web to database on the database port only	Keeps a breached web server contained
F4	Replace FTP with SFTP; disable the FTP service; prefer key-based login	Update client scripts during migration
F5	Automatic security patching; scheduled windows for application patches; asset inventory; central patch status	Cloud-managed tooling reduces manual tracking
F6	IoT in its own VLAN with no route to servers or workstations	Prefer devices with vendor-managed updates
F7	Corporate SSID on WPA-Enterprise via RADIUS; separate guest SSID, internet only	Hosted RADIUS lowers upkeep
F8	IDS/IPS, log forwarding to one place, alerts on failures, EDR on servers and workstations	Alert thresholds so nobody reads logs daily
F9-F11	Active/standby firewall, core switch, and router; dual ISP; UPS; config backups; cold-spare fallback	Redundancy needs real configuration (Section 8)
Admin path	Jump server in the Management VLAN with MFA and session logging	One system to harden and watch

7.1 Suggested sequencing

This ordering is our suggestion, based on the risk scores and effort; it is not from the scenario.

- **First:** credential reset, MFA, FTP to SFTP, asset audit (all Critical or High, low cost).
- **Second:** VLANs, DMZ, and ACLs (removes the flat-network risk).
- **Third:** redundant firewall and switch, then second ISP (needs budget approval and a maintenance window).
- **Fourth:** patch automation, IDS/IPS, logging, EDR, and a post-change security check.

7.2 Trade-offs

- **Cost:** Redundant hardware needs upfront spend; the scenario shows outages are costly too.

- **Complexity:** VLANs and ACLs add configuration work; documentation and config backups offset it.
- **User impact:** Staff reset passwords and set up MFA; the impact on daily work is small.

8. Validation and limitations

- **Not simulated.** The design is a diagram. Our Packet Tracer attempt did not pass, which is expected: drawing sync lines does not create failover.
- **What real hardware needs.** Router failover needs HSRP or VRRP; switch redundancy needs trunking with spanning tree; firewall failover needs a real HA pair. Packet Tracer does not model firewall HA, switch stacking, IDS/IPS, SIEM, or EDR, and WPA3 support depends on the version.
- **Scoring.** Likelihood and impact scores are judgment, not measured data.
- **Unconfirmed areas.** Backups, incident response, asset inventory, physical security, and email security need confirmation from Acme.
- **Next step.** Build the design in Packet Tracer or GNS3 with explicit HSRP, ACL, and VLAN configuration, then test failover and inter-zone traffic.

9. Lessons learned

- Segmentation decisions took the most debate: where the database sits and whether SFTP could live inside the internal network.
- Jump server and RADIUS were identified late, after commitments that depended on them. Listing access-control needs at the start would have caught them earlier.
- The diagram took longer than expected. Earlier feedback and clearer ownership of sections would have avoided label and subnet inconsistencies.